TS Tech & Solutions

CYBERSECURITY ASSIGNMENT PHOENIX COHORT

Student Name:	Onuoha Philip Ogbonna
Email Address:	onuohaphilip333@gmail.com

- **SCENARIO**

  It is **9:42 AM** at **TS Tech & Solutions** headquarters. The SIEM system raises a Priority-1 alert: unusual outbound traffic is detected from an internal workstation. The SOC team is paged. Within the hour, a second alert fires — an employee account is attempting to log in from two countries simultaneously.

  You have been assigned as the junior analyst on call. Your responses below will guide how TS Tech & Solutions detects, responds to, and prevents this incident — both on the ground (SOC) and at the policy level (GRC).

PART A: Security Operations (SOC) | Questions 1–8

Q1 [Fill in the Blank]
When a SIEM system raises an alert, an analyst must first triage the alert to determine whether it is a true positive or a false positive before taking any further action.

Q2 [Multiple Choice]

TS Tech's SIEM shows outbound traffic to an IP address in an unknown region at **2:00 AM**. What should the analyst check FIRST?

A. Immediately block the IP address at the firewall
B. Correlate the alert with user login logs and scheduled task activity to understand context
C. Shut down the workstation to prevent further damage
D. Email the employee and ask if they initiated the traffic

Your Answer: B. Correlate the alert with user login logs and scheduled task activity to understand context

Q3 [Short Answer]

An analyst extracts the following from logs: an outbound IP (45.33.32.156), a file hash (d41d8cd98f00b204e9800998ecf8427e), and a suspicious domain (update-service.ru). What are these called in cybersecurity, and why are they important during an investigation?

Your Answer: These are called Indicators of Compromise (IOCs). The outbound IP, file hash, and suspicious domain are artifacts left behind by an attacker that help analysts confirm a breach has occurred or is in progress. During an investigation, IOCs are critical because they can be cross-referenced against threat intelligence databases (like VirusTotal or Shodan), shared with other defenders, and used to pivot to related malicious infrastructure — speeding up containment and attribution.

Q4 [Fill in the Blank]

The NIST Incident Response Lifecycle has four phases. Arrange them in the correct order: Detection & Analysis | Preparation | Post-Incident Activity | Containment, Eradication & Recovery

1. Preparation
2. Detection & Analysis
3. Containment, Eradication & Recovery
4. Post-Incident Activity

Q5 [Critical Thinking]

The account compromise alert shows logins from Lagos and London within 3 minutes of each other. Using your knowledge of log correlation, explain in 2–3 sentences what this pattern suggests and what the analyst should do next.

Answer: A login from Lagos and London within 3 minutes is physically impossible for a legitimate user — it's a classic impossible travel indicator, strongly suggesting account compromise, likely through credential theft or phishing. The analyst should immediately suspend the account to stop active access, preserve the login logs as evidence, and begin tracing which session (if either) was legitimate by checking device fingerprints, IP

geolocation, and user-agent strings. A direct out-of-band call to the employee should follow to confirm whether they initiated either session.

Q6 [Multiple Choice]

An analyst uses a tool like VirusTotal to look up the suspicious file hash. This activity belongs to which phase of the Threat Intelligence Lifecycle?
A. Planning & Direction
B. Collection
C. Analysis & Production
D. Dissemination

Your Answer: C — Analysis & Production.

Q7 [Short Answer]

Name TWO OSINT (Open Source Intelligence) sources an analyst could use to research the suspicious domain 'update-service.ru', and briefly explain what information each source would provide.

Source 1: VirusTotal (virustotal.com)
Allows analysts to search the suspicious domain against dozens of antivirus engines and threat intelligence feeds simultaneously. It would reveal whether update-service.ru has been flagged as malicious, show associated file hashes, and surface related URLs or IPs linked to the domain.

Source 2: WHOIS / DomainTools
Provides domain registration metadata — who registered the domain, when, with which registrar, and from what country. For update-service.ru, a recently registered domain with privacy-protected or falsified registrant details would be a strong red flag consistent with attacker infrastructure.

Q8 [Critical Thinking]

After containing the incident, the SOC lead asks you to write a 3-sentence summary of what happened for the Post-Incident Report. Based on the scenario, write that summary below.

At 9:42 AM, TS Tech's SIEM flagged anomalous outbound traffic from an internal workstation to a known-suspicious IP, followed shortly by an impossible travel alert indicating the simultaneous use of an employee account from two separate countries. Investigation confirmed the account had been compromised, with an unauthorized actor leveraging stolen credentials to exfiltrate data while the legitimate user was also active. The account was suspended, affected systems were isolated, and the incident was escalated for full forensic review and remediation.

• PART B: Governance, Risk & Compliance (GRC) | Questions 9–15

Q9 [Multiple Choice]

After the incident, TS Tech's CISO says: 'We need to identify the gap, assess the likelihood it happens again, and put controls in place.' Which risk management step comes FIRST?
A. Treat
B. Monitor
C. Identify
D. Escalate
Your Answer: C. Identify

Q10 [Fill in the Blank]

Complete the Risk Management Process below by filling in the three missing stages:

Identify Risk, → Assess Risk, → Implement Controls, → Monitor, & Review.

Q11 [Matching]

Match each NIST CSF Function on the left to its correct description on the right. Write the letter in the blank.

NIST CSF Function	Answer	Description
1. Identify	C	C. Understand your assets, risks, and vulnerabilities
2. Protect	E	E. Put safeguards and controls in place to prevent attacks
3. Detect	B	B. Continuously watch for anomalies and suspicious events
4. Respond	A	A. Limit the impact once an attack is confirmed
5. Recover	D	D. Return to normal operations and improve after an incident

Q12 [Short Answer]

ISO 27001 requires organisations to maintain an 'Information Security Management System' (ISMS). In your own words, explain what an ISMS is and give ONE example of a control TS Tech & Solutions should have had in place before this incident.

Answer: An ISMS (Information Security Management System) is a structured, organization-wide framework of policies, procedures, and controls that an organization uses to systematically manage and protect its information assets — covering people, processes, and technology. It is not a one-time project but a living system that is continuously assessed and improved.

Control TS Tech should have had: Multi-Factor Authentication (MFA) enforcement on all employee accounts. Had MFA been active, stolen credentials alone would have been insufficient for the attacker to gain access, potentially preventing the account compromise entirely.

Q13 [Critical Thinking]

The account compromise happened partly because Multi-Factor Authentication (MFA) was not enforced. Using the Risk Management Process (Identify → Treat → Monitor), describe in 3 steps how TS Tech should address this gap going forward.

Step 1 (Identify) → Document the absence of MFA as a confirmed security gap, assess which accounts and systems are exposed, and determine the likelihood and potential impact of another credential-based compromise given this gap.

Step 2 (Treat) → Enforce MFA organization-wide as an immediate remediation — prioritizing privileged accounts and remote access entry points first — and update the access control policy to make MFA non-negotiable for all user accounts going forward

Step 3 (Monitor) → Integrate MFA compliance checks into the SIEM and conduct periodic access reviews to confirm enforcement has not lapsed; set alerts for any authentication attempts that bypass MFA, and include MFA posture in quarterly security audits.

Q14 [Multiple Choice]

Which statement BEST describes the difference between ISO 27001 and the NIST Cybersecurity Framework (CSF)?
A. ISO 27001 is only for large enterprises; NIST CSF is for small businesses
B. ISO 27001 is a certifiable international standard focused on building an ISMS; NIST CSF is a flexible voluntary framework focused on managing cybersecurity risk
C. NIST CSF replaces ISO 27001 and is the newer, better standard
D. Both frameworks are identical and can be used interchangeably without any adaptation

Your Answer:

B — ISO 27001 is a certifiable international standard focused on building an ISMS; NIST CSF is a flexible voluntary framework focused on managing cybersecurity risk.

Q15 [Critical Thinking]

Imagine you are presenting the incident findings to TS Tech's management team. In 3–4 sentences, explain why cybersecurity is not just a technical problem, but also a governance and compliance issue — and what could happen if GRC is ignored.

Cybersecurity is fundamentally a governance issue because the decisions that create risk — who has access to what, whether MFA is enforced, how vendors are vetted — are made at the policy and leadership level, not by technical teams alone. In this incident, the absence of MFA was not a technical failure but a governance failure: a policy was not in place, or not enforced. If GRC is ignored, organizations face compounding consequences beyond the breach itself — regulatory fines under frameworks like GDPR or NDPA, loss of client trust, legal liability, and reputational damage that technical teams cannot fix after the fact. Security without governance is reactive and fragile; governance gives security its authority and sustainability.